MedBridge Health, Inc.

Cybersecurity Risk Assessment Methodology

1. Purpose

The purpose of this risk assessment is to identify and evaluate cybersecurity risks that could affect MedBridge Health's systems, patient information, and business operations.

Since MedBridge Health handles Protected Health Information (PHI) and provides telehealth services, understanding these risks is important for protecting patient privacy and reducing potential security incidents.

This assessment will focus on the eight security weaknesses identified in the company's security environment. I'll evaluate each risk based on how likely it is to occur and the potential impact it could have on the organization.

2. Scope

This assessment covers MedBridge Health's critical systems, employee devices, cloud infrastructure, healthcare applications, and third-party services.

The areas being assessed include:

- Asset inventory and management
- Employee security awareness
- Backup and recovery
- Incident response
- Third-party vendor compliance
- Privileged account access
- Security monitoring and logging
- Employee offboarding

These areas were selected based on the simulated security weaknesses documented in Project 1.

3. Risk Assessment Approach

For this assessment, I'll use a qualitative risk assessment approach based on a 5 × 5 scoring matrix.

Each identified risk will receive a likelihood score from 1 to 5 and an impact score from 1 to 5.

The likelihood score represents how likely the risk is to occur, while the impact score represents how seriously it could affect MedBridge Health if it happens.

The following formula will calculate the overall risk score:

Risk Score = Likelihood × Impact

The final scores will help determine which risks need the most attention.

4. Likelihood Scoring

Score	Rating	Description
1	Rare	The risk is very unlikely to occur under normal conditions.
2	Unlikely	The risk could occur, but it is not expected to happen often.
3	Possible	The risk could realistically occur based on existing weaknesses or threats.
4	Likely	The risk has a strong chance of occurring because of known security weaknesses.
5	Almost Certain	The risk is expected to occur or has a very high likelihood of happening.

5. Impact Scoring

Score	Rating	Description
1	Insignificant	Little or no impact on company operations or sensitive information.
2	Minor	Limited disruption or minor security issues that can be resolved quickly.
3	Moderate	Noticeable business disruption, potential data exposure, or moderate recovery costs.
4	Major	Significant operational disruption, sensitive information exposure, or serious compliance concerns.
5	Severe	Major healthcare service disruption, widespread PHI exposure, or serious financial and regulatory consequences.

6. Risk Rating Levels

Risk Score	Rating	Priority
1–4	Low	Monitor and address through normal security improvements.
5–9	Medium	Develop corrective actions and track progress.
10–16	High	Prioritize remediation and assign a responsible risk owner.
17–25	Critical	Escalate to leadership and prioritize immediate risk treatment.

7. Risk Ownership

Each identified risk must be assigned to a responsible owner who will help manage and track the risk.

Risk owners will be selected based on their responsibilities within MedBridge Health.

Examples include:

- **CTO:** AWS security, application security, and technical infrastructure risks.
- **vCISO:** Security governance, risk assessments, and incident response planning.
- **IT Manager:** Device management, account access, backups, and security monitoring.
- **Privacy Officer:** HIPAA compliance, PHI protection, and vendor Business Associate Agreements.
- **HR Manager:** Employee onboarding, offboarding, and security awareness training.

8. Risk Treatment

After evaluating each risk, I'll recommend an appropriate treatment based on its severity and potential impact.

MedBridge Health will use four risk treatment options:

- **Mitigate:** Implement security controls to reduce the likelihood or impact of the risk.
- **Accept:** Formally acknowledge the risk and decide to retain it within approved risk tolerance.
- **Transfer:** Shift some financial or operational consequences through insurance or contractual arrangements.
- **Avoid:** Stop or change the activity that creates the risk.

Each treatment recommendation will include a responsible owner and proposed corrective actions.

9. Risk Assessment Review

The vCISO should coordinate a review of the risk register at least once every 12 months or when major changes occur that could affect MedBridge Health's security environment.

High and critical risks should be reviewed more frequently until appropriate corrective actions are completed.

The risk register should also be updated when new security weaknesses, significant incidents, or changes to critical systems are identified.

10. Assessment Disclaimer

This methodology was created for MedBridge Health, Inc., a fictional healthcare organization, as part of my hands-on GRC lab.

All risks, scores, and recommendations are simulated and based on the company's fictional security environment. They do not represent an assessment of a real healthcare organization.